INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY

Incident Response Planning Assignment

GRC105 Incident Management and Business Continuity Week 20

Act as the Incident Response Lead for a fictional training institute facing a suspected ransomware incident. Analyse the evidence, prepare a coordinated response plan, and test your decisions through a documented tabletop exercise.

Assessment detail	Requirement
Name	Farida Baberin-Yor Beacher
Student ID	2025/GCR/12741
Submission Date	20 October 2026
Programme	Governance, Compliance, and Risk Training Program
Assessment type	Individual assignment | Complete all six tasks
Total marks and weighting	100 marks | 20% of the final course grade
Submission	One Word document through the E-Campus assessment page
Deadline	As published for this assessment in E-Campus
Suggested effort	10 to 12 hours

Learning outcomes

- Classify incidents and prioritise response using evidence and business impact.
- Develop an incident response plan with clear roles, authority, and escalation.
- Sequence containment, evidence preservation, eradication, and validated recovery.

Evaluate response decisions through communication, exercises, and lessons learned.

Executive summary

Northbridge Skills Institute is experiencing a suspected ransomware incident affecting its finance workstation, file server and learning management system (LMS). The available evidence shows signs of file encryption, suspicious account activity, an unusual outbound data transfer and disruption to learner services.

The incident should be classified as Critical because it affects business operations, may involve unauthorised access to sensitive information, and threatens the institute's ability to deliver teaching and assessments. An examination is scheduled for 11:00, which makes the disruption time-sensitive.

The immediate priorities are to contain the incident, preserve evidence, protect backups, establish a trusted communication channel and restore essential services safely. The incident team must also determine whether any personal data was accessed or taken, how the attacker gained access, and whether the suspicious activity involved compromised credentials.

At this stage, the evidence does not prove that learner data was stolen, identify the attacker, or confirm that the payroll attachment executed malware. These matters require further investigation.

Task 1: Analyse the evidence and classify the incident

1.1 Evidence analysis

The following table summarises the evidence supplied in the assessment brief.

Evidence	Observation	What it may indicate
E01: Finance workstation	On Day -1 at 16:40, a finance officer opened an unexpected payroll attachment on FIN-PC07.	Possible phishing entry point. It is not yet confirmed that the attachment executed malicious code.
E02: Microsoft 365 audit logs	At 01:15 on Day 0, the finance account signed in from an unfamiliar IP address and new device.	Possible account compromise or unauthorised access. The user's legitimate activity and sign-in details must be checked.
E03: Remote logons	At 01:35, the svc_backup account made remote administrative logons to FS01 and BAK01 outside its normal schedule.	Possible misuse of a privileged service account and movement between systems. A legitimate scheduled task has not yet been ruled out.
E04: Outbound traffic	At 01:50, FIN-PC07 uploaded 1.2 GB of data through HTTPS to an unfamiliar cloud storage service.	Possible data exfiltration. The destination, contents and legitimacy of the transfer are unknown.
E05: Backup console	At 02:00, backup jobs for FS01 and LMS01 were reported as successful.	The jobs completed according to the console, but this does not establish that the backups are clean, complete or restorable.

E06: File changes	At 08:30, mass file changes were observed on FIN-PC07. FS01 contained .locked files and a ransom note.	Strong evidence of malicious file encryption and a likely ransomware incident.
E07: LMS disruption	At 08:40, users could log in to the LMS, but could not access learning materials or submit assessments.	The teaching service is operationally impaired, potentially because of encrypted or inaccessible files. The exact technical cause requires confirmation.
E08: Contact list	At 08:45, the incident contact list stored on FS01 was inaccessible. Staff mobile phones remained available, but the reliability of corporate email was uncertain.	The incident has affected response readiness and may compromise the availability or trustworthiness of normal communication channels.

1.2 Incident timeline

The timeline suggests that suspicious activity occurred before the visible encryption was discovered.

- Day -1, 16:40: A finance officer opened an unexpected payroll attachment.
- Day 0, 01:15: An unfamiliar sign-in was recorded for the finance account.
- Day 0, 01:35: The svc_backup account made unusual remote administrative logons.
- Day 0, 01:50: FIN-PC07 uploaded 1.2 GB to an unfamiliar cloud storage service.
- Day 0, 02:00: The backup console reported successful jobs for FS01 and LMS01.
- Day 0, 08:30: Mass file changes and .locked files were observed, alongside a ransom note.
- Day 0, 08:40: Learners were unable to access materials or submit assessments.
- Day 0, 08:45: The incident contact list on FS01 was inaccessible.

The evidence raises the possibility that an attacker obtained access, used an account with elevated privileges, moved between systems and transferred data before encryption became apparent. However, this is a working theory, not a confirmed reconstruction of events. The timestamps alone do not prove that all events were caused by the same person or malware.

1.3 Incident classification

Classification: Critical ransomware incident with suspected data exfiltration.

The incident is classified as Critical for the following reasons:

1. Ransomware-like encryption is confirmed by the .locked files and ransom note.
2. The LMS is disrupted, affecting learning and assessment activities.
3. A large outbound transfer raises concerns about possible data theft.

4. An account with backup privileges has made unusual remote administrative logons.
5. The incident contact list is inaccessible, complicating coordination.
6. An examination is scheduled for 11:00, increasing the urgency of restoring teaching services.

The incident should be managed as a security incident involving confidentiality, integrity and availability until investigation establishes the full impact.

Impact on confidentiality, integrity and availability

- Confidentiality: Potentially affected because of the unusual 1.2 GB outbound transfer and suspicious sign-in activity. The contents of the transfer have not been established.
- Integrity: Potentially affected because files have been changed or encrypted. Investigators must determine whether files were also modified, deleted or manipulated before encryption.
- Availability: Confirmed to be affected because files on FS01 are encrypted and learners cannot access materials or submit assessments through the LMS.

1.4 Immediate investigation questions

The response team must answer the following questions:

- Did the payroll attachment execute, and was it the initial entry point?
- Was the finance account compromised, or can the unfamiliar sign-in be explained by legitimate activity?
- Who or what used svc_backup, and were the logons authorised?
- What data was uploaded from FIN-PC07, and which cloud service received it?
- Were other endpoints, servers or cloud accounts affected?
- Are the backups clean, protected from attacker access and capable of restoring services?
- Is the LMS disruption caused by ransomware, server-side encryption or another related failure?
- Is the attacker still present in the environment?
- Is there evidence that personal data, learner records, payroll information or other confidential records were accessed?

Until these questions are answered, the institute should avoid making definitive statements about data theft or the attacker’s identity.

Task 2: Develop the incident response plan

2.1 Response objectives

The response should focus on five objectives:

1. Contain the threat: Stop further encryption, unauthorised access and potential data transfer.

2. Preserve evidence: Collect logs and forensic evidence without unnecessarily altering affected systems.
3. Protect critical assets: Secure backup infrastructure, privileged accounts and unaffected systems.
4. Restore essential services: Bring the LMS and other priority services back online only after they have been checked.
5. Manage the impact: Keep leadership, staff, learners and relevant authorities informed through approved communication channels.

The response should follow the incident response lifecycle in the teaching material and be consistent with recognised guidance, including NIST SP 800-61 Rev. 3 and CISA's ransomware response recommendations. NIST SP 800-61 Rev. 3 · CISA #StopRansomware Guide

2.2 Response team and responsibilities

Role	Main responsibilities
Incident Response Lead	Declares and coordinates the response, sets priorities, maintains the incident log and provides updates to leadership.
IT Infrastructure Lead	Isolates affected systems, checks network and server status, and coordinates technical recovery.
Security Analyst / Forensic Investigator	Examines logs, collects evidence, develops the incident timeline and investigates the suspected entry point and data transfer.
Identity and Access Administrator	Reviews suspicious sign-ins, disables or restricts compromised accounts and secures privileged access.
Backup and Recovery Lead	Protects backup infrastructure, validates recovery points and coordinates restoration.
Data Protection Officer / Legal Adviser	Assesses potential personal data exposure, advises on notification obligations and maintains a record of decisions.
Communications Lead	Prepares approved communications for staff, learners and other stakeholders.
Executive Sponsor	Approves major business decisions, including service priorities, examination arrangements and significant recovery decisions.
Academic Operations Lead	Assesses learner impact, coordinates alternative teaching arrangements and communicates examination changes.

In a small organisation, one person may perform more than one role. However, responsibilities should be clearly assigned, particularly for evidence handling, recovery approval and external communications.

2.3 Incident response phases

Phase 1: Detection and initial assessment

- Record the incident time, reporter, affected systems and initial observations.
- Confirm the ransom note and encrypted files without running suspicious files.
- Review available endpoint, server, firewall and Microsoft 365 logs.
- Identify affected services and establish whether encryption or suspicious activity is continuing.
- Assign a severity level and activate the response team.

Expected result: A documented incident record, a preliminary impact assessment and a clearly assigned response lead.

Phase 2: Containment

- Isolate FIN-PC07 from the network.
- Restrict network access to affected servers where necessary to stop further spread.
- Review and restrict the svc_backup account and any other suspected compromised credentials.
- Secure the backup management console and prevent unauthorised access to backup repositories.
- Block confirmed malicious indicators, such as a verified command-and-control destination, where this can be done safely.
- Check for other affected endpoints and accounts before assuming the incident is limited to the known systems.

Isolation should be coordinated with the forensic investigator where practical. If active encryption is spreading, immediate containment takes priority, but the team should record what actions were taken and when.

Phase 3: Investigation and evidence preservation

- Preserve Microsoft 365 sign-in and audit logs, endpoint telemetry, firewall logs, server logs and backup logs.
- Capture relevant volatile evidence where appropriate and where trained personnel are available.
- Create forensic images of affected devices when feasible.
- Record system identifiers, timestamps, collection methods, hashes and the names of the people handling evidence.
- Investigate the 1.2 GB transfer, including the destination and available evidence of the transferred data.
- Determine whether the attacker accessed other systems or maintained persistence.

Phase 4: Eradication

- Identify and remove the malware or other unauthorised access mechanisms.
- Patch exploited vulnerabilities and correct the initial access route where established.
- Reset compromised passwords and revoke active sessions or tokens where appropriate.
- Review service accounts, permissions and administrative access.
- Check that the attacker has not left other persistence mechanisms in the environment.

The team should not rebuild systems until sufficient evidence has been collected, unless immediate business or safety needs require an earlier action. Any decision to proceed should be documented.

Phase 5: Recovery

- Select a known-good backup or recovery point.
- Validate backup integrity and scan restored systems before reconnecting them to production.
- Restore services in an agreed order, beginning with the most critical dependencies.
- Test authentication, file access, LMS functionality and learner submission workflows.
- Monitor systems closely for renewed suspicious activity.
- Obtain formal approval before declaring services fully restored.

Phase 6: Lessons learned

- Conduct a post-incident review.
- Document the cause, impact, response actions and recovery duration.
- Identify weaknesses in email security, identity management, network segmentation, backup protection and monitoring.
- Assign owners and deadlines for corrective actions.
- Update the response plan and conduct a follow-up exercise.

2.4 RACI matrix

RACI identifies who is Responsible for carrying out work, Accountable for the outcome, Consulted for input and Informed of progress.

Roles: IRL = Incident Response Lead; IT = Infrastructure Lead; DF = Forensic Investigator; IAM = Identity Administrator; BR = Backup/Recovery Lead; DPO = Data Protection Officer/Legal; COMMS = Communications Lead; EXEC = Executive Sponsor; ACAD = Academic Operations Lead.

Activity	IRL	IT	DF	IAM	BR	DPO	COMMS	EXEC	ACAD
Declare incident and set severity	R	C	C	I	I	C	I	A	I

Isolate affected systems	A	R	C	C	C	I	I	I	I
Preserve and analyse evidence	A	C	R	C	C	C	I	I	I
Restrict compromised accounts	A	C	C	R	C	I	I	I	I
Protect and validate backups	A	C	C	C	R	I	I	I	I
Assess personal data exposure	C	C	R	C	I	A	I	I	I
Approve major business decisions	R	C	C	I	C	C	C	A	C
Communicate with learners and staff	C	I	I	I	I	C	R	A	C
Restore critical services	A	R	C	C	R	I	I	I	C
Lead post-incident review	A/R	C	C	C	C	C	C	I	C

The Incident Response Lead coordinates the overall response. The Executive Sponsor remains accountable for major business decisions. The DPO or legal adviser leads the assessment of data protection obligations, while technical specialists provide the evidence needed for that assessment.

2.5 Readiness improvements

Northbridge should prepare for future incidents by:

- Maintaining an incident contact list outside the main file server.
- Keeping offline or otherwise protected backups and testing restoration regularly.
- Requiring multifactor authentication and reviewing privileged accounts.
- Monitoring unusual service-account logons and large outbound transfers.
- Improving email filtering and staff phishing awareness.
- Documenting network dependencies and isolation procedures.
- Keeping a current inventory of critical systems and their business owners.
- Running tabletop exercises that include ransomware, suspected data theft and loss of normal communication channels.

These improvements should have named owners and deadlines rather than remain general recommendations.

Task 3: Prepare the incident response playbook

This playbook sets out what the response team should do during the first 24 hours. The times below are proposed response times for the scenario, not actual actions already taken.

3.1 First 15 minutes: 08:45 to 09:00

Incident Response Lead

- Declare a Critical incident and open an incident log.
- Record the known affected systems, current business impact and evidence references.
- Contact the response team using staff mobile phones or another verified communication channel.
- Advise leadership that the LMS is disrupted and the 11:00 examination may be affected.
- Instruct staff not to delete files, restart affected machines unnecessarily or attempt their own recovery.

Infrastructure and security teams

- Isolate FIN-PC07 from the network.
- Assess whether FS01, BAK01 or other systems are still experiencing active encryption.
- Restrict affected network connections where required to stop further spread.
- Avoid connecting backup storage to potentially compromised systems.
- Preserve the ransom note and visible error messages through documented photographs or screenshots where appropriate.

Expected outcome: The incident is formally declared, the response team is activated and immediate steps are taken to prevent further damage.

3.2 First hour: 09:00 to 09:45

Containment and account security

1. Identify systems that are confirmed affected and those that may be affected.
2. Review the svc_backup account’s permissions and recent activity.
3. Restrict or disable the account if unauthorised use is reasonably suspected, while checking for operational dependencies.
4. Review the finance account’s sign-in history, active sessions and authentication events.
5. Revoke sessions or reset credentials where justified by the evidence.
6. Review remote administrative access and prevent unapproved connections to affected systems.
7. Preserve available network and endpoint logs before retention periods or system changes cause evidence to be lost.

Changes to accounts and systems should be documented, including the time, person responsible, reason and observed result.

Business continuity

The Academic Operations Lead should determine whether the 11:00 examination can proceed safely. The institute should not promise that the examination will take place until the availability and integrity of the required systems have been confirmed.

If the LMS cannot be restored safely, leadership should decide whether to postpone the examination or use an approved alternative arrangement. Any alternative must protect learner records and assessment integrity.

3.3 Hours 1 to 4: investigation and recovery planning

The forensic investigator should:

- Collect the relevant Microsoft 365 sign-in and audit logs.
- Obtain available endpoint detection, firewall, DNS, VPN and server logs.
- Investigate the 1.2 GB upload from FIN-PC07.
- Examine the unusual remote logons involving svc_backup.
- Identify whether other endpoints or accounts show similar behaviour.
- Build a timeline of confirmed events and record which links between events remain unproven.

The Backup and Recovery Lead should:

- Check whether the backup console or repositories were accessed using compromised credentials.
- Identify the last known-good backup for FS01 and LMS01.
- Check backup logs for unusual deletions, configuration changes or failed integrity checks.
- Confirm that restoration can take place in an isolated environment.
- Avoid declaring the backups safe solely because the console reported successful jobs.

The team should then prepare a recovery order based on business impact and technical dependencies. The LMS, identity services, file services and other supporting systems may have different restoration requirements.

3.4 Hours 4 to 24: eradication and controlled restoration

Once evidence collection and containment are sufficiently advanced:

- Remove identified malware and unauthorised persistence mechanisms.
- Rebuild affected systems from trusted installation media or clean images where appropriate.
- Apply security updates and correct the confirmed entry point where known.
- Reset affected credentials and review privileged permissions.
- Restore from validated backups in an isolated environment.

- Test the LMS using representative learner and administrator accounts.
- Confirm that materials can be accessed and assessments can be submitted.
- Monitor restored systems for unusual authentication, file activity and outbound connections.
- Obtain approval from the Incident Response Lead and relevant service owner before reconnecting each system to production.

If the initial access route or the attacker's persistence has not been understood sufficiently, recovery must include additional monitoring and risk controls.

3.5 Evidence preservation procedure

Evidence preservation is essential because the institute may need to determine the scope of the incident, support legal or regulatory decisions and explain what happened.

The response team should use the following procedure.

1. Identify and record evidence

Assign each item a unique identifier, such as E01 or E02. Record the system, date and time, collector, collection method and relevance to the investigation.

2. Preserve original data

Do not edit original logs, delete suspicious files or run malware samples on normal business systems. Where possible, create forensic copies and conduct analysis on those copies.

3. Record timestamps

Record the system's timezone and any known clock differences. This is important when correlating Microsoft 365, endpoint, firewall and server events.

4. Calculate hashes

Where appropriate, calculate cryptographic hashes such as SHA-256 for collected forensic images and exported evidence files. Record the hash values so later copies can be checked for changes.

5. Maintain chain of custody

Every transfer of evidence should be documented. The record should state who released the evidence, who received it, when the transfer took place and why.

6. Secure the evidence

Store evidence in a restricted location with access logging. Keep working copies separate from preserved originals and limit access to authorised personnel.

7. Document unavoidable changes

Isolation, account disabling and shutdowns may alter system state. The team should record what it did, when it did it and why, including emergency actions taken before evidence could be collected.

Example evidence register

Evidence ID	Item	Collection action	Required record
EV-01	FIN-PC07	Isolate, document system state and arrange forensic acquisition	Asset identifier, collection time, collector, hashes
EV-02	Microsoft 365 audit data	Export relevant sign-in and audit records	Query range, export method, timestamps, file hash
EV-03	FS01	Preserve ransom note, file metadata and relevant server logs	Paths, timestamps, collection method
EV-04	svc_backup activity	Collect authentication and administrative activity logs	Account, source, destination, event times
EV-05	Outbound transfer	Preserve firewall, proxy, DNS and endpoint records	Destination, volume, timestamps and available content evidence
EV-06	Backup infrastructure	Preserve job history, access records and configuration changes	Backup set, access history, validation results

The register should be updated as evidence is collected. The entries above are proposed evidence items, not a claim that all have already been acquired.

3.6 Recovery and closure criteria

The incident should not be closed simply because the ransom note disappears or the LMS becomes available again.

Before closure, the team should confirm that:

- The known affected systems have been rebuilt or cleaned and checked.
- Backups used for restoration have been validated.
- Critical services pass functional and security tests.
- Compromised accounts, credentials and sessions have been addressed.
- Available evidence has been preserved and reviewed.
- The investigation has documented the known scope and outstanding uncertainties.
- Data protection and other notification decisions have been recorded.
- Leadership and service owners have accepted the remaining risks.
- Corrective actions have owners and deadlines.

CISA's ransomware guidance also emphasises containment, evidence preservation and recovery from backups that are not themselves compromised. These actions support the proposed playbook. CISA #StopRansomware Guide

Task 4: Draft stakeholder communications

Communication should be accurate, timely and approved by the appropriate person. Messages must not claim that data has been stolen or that systems are safe unless the investigation supports those statements.

Because the incident contact list is stored on an inaccessible server, the institute should use a verified alternative channel. Corporate email should not be treated as trustworthy until the response team has assessed the relevant accounts and systems.

4.1 Communication plan

Stakeholder	Information required	Channel	Timing	Owner
Executive leadership	Severity, business impact, major risks, decisions needed	Verified phone call or approved secure channel	Immediately, then at agreed intervals	Incident Response Lead
IT and security team	Affected systems, containment actions, evidence handling and task assignments	Verified staff phones or trusted incident channel	Immediately and continuously as needed	Incident Response Lead
Academic staff	LMS disruption, examination arrangements and approved alternatives	Verified staff communication channel	As soon as operational decisions are made	Academic Operations Lead
Learners	Service availability, assessment arrangements and where to obtain updates	Verified public or learner communication channel	Once the immediate arrangements are confirmed	Communications Lead
Data Protection Officer and legal adviser	Possible personal data exposure, evidence gaps and notification considerations	Direct, trusted communication	As early as possible	Incident Response Lead

Data Protection Commission or other authorities	Relevant facts and any required notification	Official channel, following legal assessment	As required by applicable obligations	DPO / Legal Adviser
Service providers	Relevant indicators, logs, account security and technical assistance	Verified support channel	As required	Infrastructure Lead

4.2 Initial briefing to executive leadership

Good morning,

We are responding to a Critical security incident affecting the institute's finance workstation, file server and learning management system.

The current evidence includes encrypted files and a ransom note on FS01, unusual activity involving the finance and backup accounts, and a 1.2 GB outbound transfer from FIN-PC07 to an unfamiliar cloud storage service. Learners are also unable to access materials or submit assessments through the LMS.

We have not yet confirmed whether personal data was taken or identified the initial point of compromise. The IT and security teams are working to contain the incident, preserve evidence and assess whether the backups can be used safely.

The 11:00 examination may be affected. Academic Operations and leadership need to agree on the next steps and the communication to learners.

I will provide further updates as the investigation progresses. Decisions and actions will be documented.

Regards,

Incident Response Lead

4.3 Notice to learners

Notice: Temporary disruption to learning services

We are currently experiencing a technical security incident affecting access to some learning materials and assessment submissions.

Our IT team is investigating the issue and working to restore services safely. We will provide an update on the status of the 11:00 examination as soon as a decision has been made.

Please do not repeatedly retry failed submissions. Keep any relevant screenshots or confirmation messages, and follow the instructions provided through the institute's verified communication channels.

We apologise for the disruption and will share further updates when confirmed information is available.

This notice does not speculate about data theft, name an attacker or promise a restoration time that has not been established.

4.4 Update to staff

Subject: IT security incident and temporary service disruption

We are investigating a security incident affecting some institute systems, including the learning management system.

Please do not attempt to repair affected devices, delete suspicious files, reconnect isolated equipment or use unapproved tools to recover data. If you notice unusual activity, record what you observed and report it through the verified incident communication channel.

Use only approved communication channels for incident-related information. Further instructions about teaching activities and assessments will be shared when confirmed.

Thank you for your cooperation.

4.5 Data protection and regulatory considerations

The 1.2 GB outbound transfer creates a reason to investigate whether personal data may have been accessed or acquired without authority. It does not, by itself, establish that personal data was included.

The DPO and legal adviser should determine:

- What data was stored on the affected systems.
- Whether the transferred data can be identified from available logs and forensic evidence.
- Whether there is evidence of unauthorised access or acquisition of personal data.
- Which individuals, if any, may be affected.
- Which notification obligations apply and what information should be provided.
- Whether further updates are needed as the investigation develops.

For an institute operating in Ghana, section 31 of the Data Protection Act, 2012 (Act 843) is relevant to security compromises involving personal data. The DPO and legal adviser should assess the facts against the Act and confirm the applicable notification requirements. The institute should not assume a fixed notification deadline taken from a different jurisdiction without checking whether it applies.

Reference: Ghana Data Protection Act, 2012 (Act 843).

Task 5: Conduct and document a tabletop simulation

5.1 Purpose

The tabletop exercise tests whether Northbridge’s incident response arrangements work when ransomware affects several systems, normal communication channels are unreliable and an important examination is approaching.

This is a simulated exercise. The decisions and outcomes below are proposed exercise responses, not real actions taken by Northbridge.

Participants

- Incident Response Lead
- IT Infrastructure Lead
- Forensic Investigator
- Identity and Access Administrator
- Backup and Recovery Lead
- Data Protection Officer or legal adviser
- Communications Lead
- Executive Sponsor
- Academic Operations Lead

5.2 Scenario and injects

Inject 1: 08:45, ransomware confirmed

Situation: The team receives reports of .locked files on FS01 and a ransom note. The LMS is unavailable for learning materials and submissions.

Question: Who declares the incident, and what are the first actions?

Expected response:

- The Incident Response Lead declares a Critical incident.
- The team opens an incident log and assigns responsibilities.
- FIN-PC07 is isolated.
- The team assesses whether encryption is continuing on FS01 or other systems.
- Leadership and Academic Operations are informed.
- Evidence is preserved where possible before non-essential changes are made.

Evaluation: A good response gives containment priority while preserving an accurate record of actions and decisions.

Inject 2: 09:00, suspicious backup account activity

Situation: The svc_backup account has made unusual remote administrative logons to FS01 and BAK01.

Question: Should the team disable the account immediately?

Expected response:

The team should treat the activity as suspicious and assess whether it is authorised. If there is a reasonable risk that the account is compromised, access should be restricted promptly, with operational dependencies considered and the action documented.

The team should review relevant authentication logs, account permissions and the backup infrastructure. It must not assume the account is malicious solely because the activity occurred outside the normal schedule.

Evaluation: The decision should balance containment with the risk of interrupting legitimate backup or recovery operations.

Inject 3: 09:15, possible data exfiltration

Situation: The investigation confirms that FIN-PC07 uploaded 1.2 GB of data to an unfamiliar cloud storage destination.

Question: What should the team tell leadership, learners and the DPO?

Expected response:

- Inform the DPO and legal adviser promptly.
- Preserve available network, endpoint and cloud audit evidence.
- Investigate what data was transferred and whether the destination is linked to the incident.
- Tell leadership that a large transfer occurred and possible data exposure is being investigated.
- Avoid stating that learner or payroll data was stolen until evidence supports that conclusion.

Evaluation: Communications should distinguish the confirmed transfer from the unresolved question of what it contained.

Inject 4: 09:30, backup jobs reported successful

Situation: The backup console shows successful jobs for FS01 and LMS01, but the team cannot yet establish whether the backups are clean.

Question: Should the team start restoring immediately?

Expected response:

The Backup and Recovery Lead should check backup access history, integrity and available recovery points. Restoration should occur in an isolated environment using a validated recovery point. The team should confirm that the backup infrastructure itself has not been compromised.

Evaluation: A successful backup job is not sufficient proof that a backup is safe or recoverable.

Inject 5: 09:45, examination starts at 11:00

Situation: Learners still cannot access materials or submit assessments.

Question: Who decides whether the examination proceeds?

Expected response:

The Executive Sponsor should make the business decision with advice from the Incident Response Lead and Academic Operations Lead. The decision should consider service integrity, fairness to learners, available alternatives and the risk of reconnecting systems too early.

If the LMS cannot be restored safely, the institute should communicate a postponement or approved alternative through a verified channel.

Evaluation: Business continuity decisions should be explicit, timely and recorded.

Inject 6: 10:00, contact list unavailable

Situation: The contact list is stored on FS01, which is inaccessible, and corporate email has not been confirmed as trustworthy.

Question: How does the team coordinate and communicate?

Expected response:

- Use verified staff phone numbers and another approved communication method.
- Maintain a contact list and incident record outside the affected file server.
- Verify recipients before sharing sensitive incident details.
- Avoid sending credentials, forensic evidence or confidential information through untrusted channels.
- Record important decisions and messages for later review.

Evaluation: The exercise highlights the need for an offline contact list and a communication plan that remains usable during a system outage.

5.3 Decision log

Decision	Proposed action	Reason
Declare incident Critical	Activate the response team immediately	Encryption and teaching disruption are confirmed, with possible data exposure
Isolate FIN-PC07	Disconnect it from normal network access	Reduce the risk of continued malicious activity or spread
Restrict svc_backup	Review and restrict suspicious privileged access	Protect servers and backup infrastructure
Preserve evidence	Collect relevant logs and forensic data	Establish scope, sequence and possible data exposure
Validate backups	Test recovery points in isolation	Avoid restoring compromised systems or reintroducing the threat

Decide examination arrangements	Executive Sponsor consults Academic Operations and the IR Lead	Protect learner fairness and avoid unsafe restoration
Assess notification obligations	DPO and legal adviser review the evidence	Ensure regulatory decisions are based on the applicable law and known facts

5.4 Tabletop findings and improvement plan

The simulation reveals several likely weaknesses that need to be checked against Northbridge's actual arrangements.

Finding	Recommended improvement	Suggested owner	Priority
Contact list stored on an affected server	Maintain an offline copy and a verified alternative contact method	Incident Response Lead	High
Suspicious service-account activity	Review service-account privileges, authentication and monitoring	Identity Administrator	High
Large outbound transfer	Improve alerting for unusual outbound traffic and investigate destinations	Security Analyst	High
Backup status unclear	Test restore procedures and protect backup administration separately	Backup and Recovery Lead	High
LMS disruption affects assessments	Document examination continuity and postponement procedures	Academic Operations Lead	High
Data exposure uncertain	Establish a process for evidence-led privacy assessment and notification	DPO / Legal Adviser	High
Incident decisions may be difficult to reconstruct	Maintain a decision log with timestamps and owners	Incident Response Lead	Medium
Staff may use unapproved recovery methods	Provide clear incident instructions and conduct regular exercises	IT and Communications Leads	Medium

These findings should be converted into an action tracker with deadlines and evidence of completion. A follow-up exercise should test whether the contact list, backup recovery and examination continuity procedures now work.

Task 6: Evaluate the healthcare ransomware case study

6.1 Summary of the case study

The healthcare case study in the teaching slides describes a mid-sized organisation with approximately 2,500 employees. A phishing attachment was used as the entry point for a Ryuk ransomware variant. The attacker moved through the network without being detected for approximately 72 hours.

On Day 4, endpoint detection and response (EDR) alerts triggered an investigation. The response team isolated affected network segments and quarantined impacted systems. Offline backups remained intact.

Between Days 5 and 7, the organisation conducted forensic investigations, removed malware, rebuilt systems from clean backups and restored services in phases. A post-incident review took place on Day 14.

The reported outcomes were:

- No ransom was paid.
- Critical systems were restored within 72 hours.
- No patient data exfiltration was confirmed.
- Notifications were completed on time.
- Full restoration was achieved within seven days.

The teaching slides identify email security and staff training, network segmentation, offline backups, prepared response teams and playbooks, backup testing, and threat intelligence sharing as key lessons.

6.2 What the organisation did well

1. It isolated affected systems

The response team isolated network segments and quarantined impacted systems after the EDR alerts triggered. This helped limit further spread.

This was an important action because ransomware can move between connected systems. However, the case does not establish whether earlier monitoring could have detected the attacker before the fourth day.

Recommendation: Northbridge should document which systems can be isolated, who has authority to isolate them and how the decision will be recorded. The team should practise these actions before a real incident.

2. It had offline backups

The case study reports that offline backups remained intact. This gave the organisation a recovery option without relying on the attacker or paying a ransom.

Backups are only useful if they are accessible when needed, contain the required data and can be restored within an acceptable time.

Recommendation: Northbridge should protect backup infrastructure with separate administrative controls and test restoration regularly. A successful backup-job message should not be treated as proof that the data is recoverable or clean.

3. It used forensic investigation before completing recovery

The organisation carried out forensic investigation and malware removal before rebuilding and restoring systems. This was better than simply deleting encrypted files or reconnecting systems without understanding the threat.

Recommendation: Northbridge should preserve relevant logs and forensic evidence before rebuilding affected systems, where operational circumstances permit. Investigators should also check for compromised accounts, persistence and lateral movement.

4. It restored services in phases

The case describes a phased restoration rather than bringing all systems back online at once. This allows teams to test individual services and monitor for further malicious activity.

Recommendation: Northbridge should establish a recovery order based on business priorities and system dependencies. For this institute, the LMS and the services it depends on require particular attention because teaching and assessments may be disrupted.

5. It conducted a post-incident review

The review on Day 14 provided an opportunity to assess what happened and identify improvements.

Recommendation: Northbridge should document lessons learned, assign owners to corrective actions and track those actions to completion. A review should also examine why suspicious activity was not detected earlier and whether the incident response plan worked as intended.

6.3 What could have been improved

1. The attacker remained undetected for approximately 72 hours

The delay between initial access and detection suggests that the organisation’s monitoring and response capabilities did not identify the activity early enough.

The case study does not explain exactly which controls failed, so it would be inaccurate to claim that a specific alert or security product was missing.

Improvement: Review endpoint monitoring, authentication logs, unusual administrative activity and network traffic. Test whether the organisation can detect suspicious behaviour before ransomware becomes visible.

For Northbridge, the unusual finance-account sign-in, svc_backup logons and 1.2 GB upload are warning signs that should be investigated together, without assuming they are automatically linked.

2. Phishing remained a successful entry point

The incident began with a phishing attachment. Staff training alone is not sufficient to prevent every phishing attack.

Improvement: Combine staff awareness with email filtering, attachment and link protection, multifactor authentication, least-privilege access and endpoint monitoring. Phishing exercises should be followed by targeted guidance rather than treated only as a compliance activity.

3. Lateral movement required a response

The case indicates that the attacker moved through the network before detection. This suggests that access to one system created opportunities to reach others, although the precise network weaknesses are not described.

Improvement: Review network segmentation and administrative access. Separate critical services, restrict unnecessary communication between systems and ensure that privileged accounts cannot be used freely across the environment.

4. Recovery speed needs to be measured against business requirements

The case reports that critical systems were restored within 72 hours and full restoration took seven days. Those are useful results, but they do not by themselves show whether the recovery met every business requirement.

Improvement: Define recovery time objectives (RTOs) and recovery point objectives (RPOs) for critical services. Test whether backups and restoration procedures can meet them.

For Northbridge, the LMS and assessment services should have documented recovery priorities and contingency arrangements for examinations.

5. Threat intelligence and information sharing should be actionable

The slides identify threat intelligence sharing as a lesson. Sharing information can help organisations recognise known indicators and attack methods, but it must be relevant to the systems being protected.

Improvement: Establish a process for reviewing credible threat information, applying relevant indicators to monitoring and security controls, and sharing information with appropriate trusted parties when useful.

6.4 Applying the healthcare case to Northbridge Skills Institute

Lesson from healthcare case	Application to Northbridge
Detect suspicious activity early	Monitor unusual Microsoft 365 sign-ins, privileged service-account logons and large outbound transfers.
Contain affected systems	Practise isolating endpoints and servers without unnecessarily disrupting unaffected services.
Maintain offline backups	Protect backups from compromised administrator accounts and test restoration.
Use forensic investigation	Preserve endpoint, cloud, server and network evidence before rebuilding where practical.
Restore in phases	Validate recovery points and test the LMS before returning it to production.
Prepare response procedures	Maintain an accessible contact list, response playbook and clear decision-making responsibilities.

Communicate and notify appropriately	Involve the DPO and legal adviser early if personal data may have been compromised.
Review the incident	Assign corrective actions and verify that they have been completed.

The healthcare case demonstrates the value of preparation, containment and tested recovery. Northbridge should apply these lessons before an incident occurs, particularly because a ransomware incident can affect both IT operations and the institute's ability to deliver teaching.

One important distinction is that the healthcare case reports that no patient data exfiltration was confirmed. This does not necessarily prove that no data was accessed; it means the case study did not confirm exfiltration. Similarly, Northbridge must not interpret the absence of confirmed data theft as proof that no data was exposed.

Conclusion

The evidence provided for Northbridge Skills Institute supports classifying the event as a Critical ransomware incident with suspected data exfiltration. Encryption and LMS disruption are confirmed observations, while the initial infection route, the identity of the attacker and the contents of the outbound transfer remain unresolved.

The response should prioritise containment, evidence preservation, account security, backup protection and controlled service restoration. Communication should be timely but limited to verified information. The DPO and legal adviser should assess the available evidence against applicable data protection obligations.

The healthcare case study reinforces the importance of early detection, network segmentation, offline backups, forensic investigation and phased recovery. Northbridge should use the incident to test its readiness and turn identified gaps into specific, measurable improvements.

References

1. ICDFA. (n.d.). Incident Response Planning. See slide 16 for the healthcare ransomware case study.

2. National Institute of Standards and Technology (NIST). (2025). Incident Response Recommendations and Considerations for Cybersecurity Risk Management: A CSF 2.0 Community Profile (SP 800-61 Rev. 3). https://csrc.nist.gov/pubs/sp/800/61/r3/final

3. Cybersecurity and Infrastructure Security Agency (CISA). (n.d.). #StopRansomware Guide. https://www.cisa.gov/stopransomware/ransomware-guide

4. Republic of Ghana. (2012). Data Protection Act, 2012 (Act 843). https://ghalii.org/akn/gh/act/2012/843/eng@2012-05-18